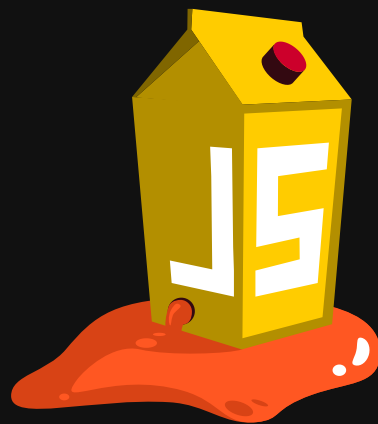


OWASP Juice Shop 20.1.1

🌴 Sommer, ☀ Sonne, 📺 24 H Saftladen

@OWASP Hamburg Stammtisch, 28.07.2026



<https://owasp-juice.shop>

Björn Kimminich | infosec.exchange/@bkimminich | [@bkimminich.bsky.social](https://bsky.social/@bkimminich)
Jannik Hollenbach | infosec.exchange/@jannik | [@jannik-hollenbach.bsky.social](https://bsky.social/@jannik-hollenbach)

Follow @owasp_juiceshop

Follow @owasp_juiceshop

133

bluesky Follow

Star

13,588

Follow r/owasp_juiceshop

503

Who are we?

Björn Kimminich

Jannik Hollenbach



IT Product Group Lead
@Kuehne+Nagel

Software Security Engineer
@iteratec

Project Leader OWASP Juice Shop
Chair OWASP Project Committee

Project Leader OWASP Juice Shop
Project Leader OWASP SecureCodeBox

🏆 WASPY Award 2021
"Outstanding Innovator"

🏆 WASPY Award 2025
"Project Person of the Year"

What is this *Juice Shop*?



OWASP JUICE SHOP

OWASP Juice Shop is probably the most modern and sophisticated insecure web application! It can be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools! Juice Shop encompasses vulnerabilities from the entire OWASP Top Ten along with many other security flaws found in real-world applications!

Customer Testimonials

DSCHADOW
The most trustworthy online shop out there.

SHEHACKSPURPLE
The best juice shop on the whole internet!

VANDERAJ
Actually the most bug-free vulnerable application in existence!

<http://owasp-juice.shop> | [@owasp_juiceshop](https://twitter.com/owasp_juiceshop)



JUICE SHOP CTF Extension

The Node package `juice-shop-ctf-cli` helps you to prepare Capture the Flag events with the OWASP Juice Shop challenges for different popular CTF frameworks. This interactive utility allows you to populate a CTF game server in a matter of minutes.

<http://ctf.owasp-juice.shop>

Main selling points

FREE
<http://ebook!owasp-juice.shop>

- Free and Open source: Licensed under the MIT license with no hidden costs or caveats
- Easy-to-install: Choose between node.js, Docker and Vagrant to run on Windows/Mac/Linux
- Self-contained: Additional dependencies are pre-packaged or will be resolved and downloaded automatically
- Self-healing: The simple SQLite and MarsDB databases are wiped and repopulated from scratch on every server startup
- Gamification: The application notifies you on solved challenges and keeps track of successfully exploited vulnerabilities on a Score Board
- Re-branding: Fully customizable in business context and look & feel to your own corporate or customer requirements
- CTF-support: Challenge notifications optionally contain a flag code for your own Capture-The-Flag events

PWINING OWASP JUICE SHOP
BJORN KIMMINICH

<http://owasp-juice.shop> | [@owasp_juiceshop](https://twitter.com/owasp_juiceshop)

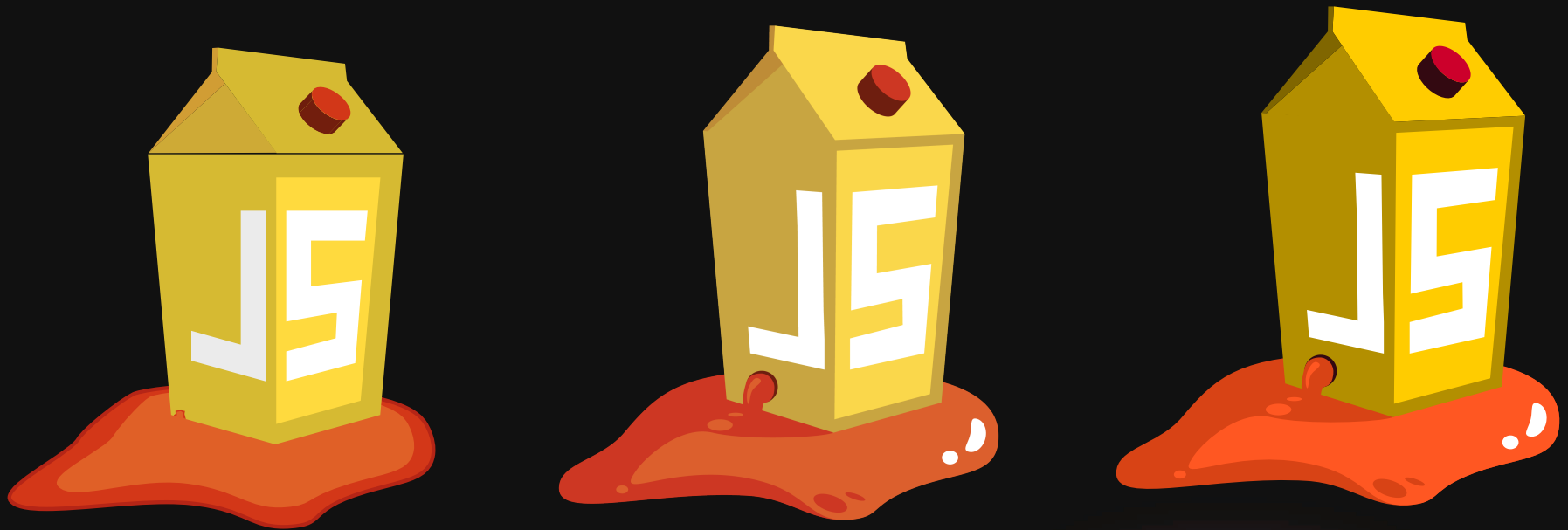




in Juice Shop

First logo update in 10 years

The color palette was updated to a more vibrant and "popping" one



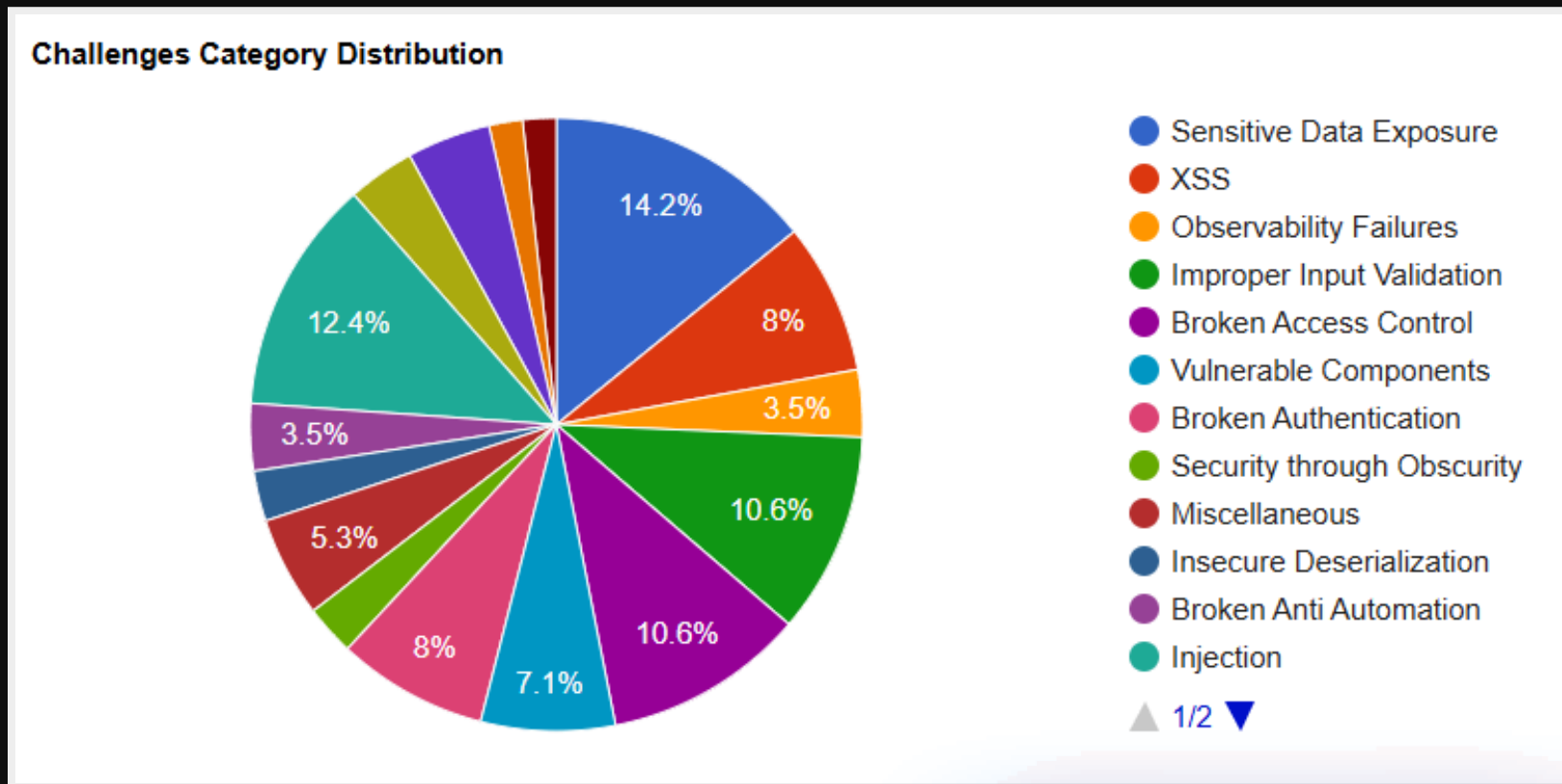
2014

2017

2026

Hacking Challenges

Covering various vulnerabilities and serious design flaws



Covers all of the latest **OWASP Top 10** and now even some of the **OWASP Top 10 for LLM Applications**.

Score Board

New design for easier progress tracking & picking next challenges

The screenshot displays the OWASP Juice Shop Score Board. At the top, the header includes the OWASP Juice Shop logo, a search bar, and links for Account, Your Basket, and EN. Below the header, three progress bars are shown: Hacking Challenges (4%), Coding Challenges (2%), and Challenges Solved (5/178). A filter bar contains various tags such as All, Broken Access Control, XSS, Observability Failures, Improper Input Validation, Unvalidated Redirects, Vulnerable Components, Broken Authentication, Security through Obscurity, Insecure Deserialization, Broken Anti Automation, Injection, Sensitive Data Exposure, Security Misconfiguration, Cryptographic Issues, Miscellaneous, and XXE. A notification states: "1 challenges are unavailable on Windows due to security concerns or technical incompatibility". The main content area is a grid of challenge cards. Each card displays the challenge name, a description, a difficulty level (indicated by stars), and a progress indicator (a green bar with a number). A tooltip is visible over the 'DOM XSS' challenge, stating: "Marks challenges which need to be solved before one or more other challenges can be (realistically) solved." The challenge cards include: Score Board, DOM XSS, Bonus Payload, Privacy Policy, Confidential Document, Error Handling, Exposed Metrics, Mass Dispel, Missing Encoding, Repetitive Registration, Web3 Sandbox, Zero Stars, Reflected XSS, Exposed credentials, Login Admin, Admin Section, Password Strength, 16xus Backed, and A Debugging.

Challenge Hints

All challenges come with one or more unlockable hints

The screenshot displays a challenge interface with two main sections. The top section is titled 'Improper Input Validation' and contains a challenge named 'Expired Coupon' with a difficulty of four stars. The description is 'Successfully redeem an expired campaign coupon code.' and it has a hint counter of 1/3. The bottom section is titled 'XSS' and contains a challenge named 'HTTP-Header XSS' with a difficulty of one star. The description is 'Perform a *persisted* XSS attack with `<iframe src="javascript:alert(`xss`)">` header.' and it has a hint counter of 0/3. A hint box is overlaid on the 'HTTP-Header XSS' challenge, containing the text: '1. Try to identify past special event or holiday campaigns of the shop first. Click to unlock hint 2 of 3!'. The interface also includes a 'Danger Zone' button and a 'Shenan' button.

Improper Input Validation

● **Expired Coupon** ★★★★★

Successfully redeem an expired campaign coupon code.

💡 1/3

XSS

● **HTTP-Header XSS**

Perform a *persisted* XSS attack with `<iframe src="javascript:alert(`xss`)">` header.

Danger Zone

Shenan

1. Try to identify past special event or holiday campaigns of the shop first.

Click to unlock hint 2 of 3!

💡 0/3

Coding Challenges

Identify the underlying code flaw and select an appropriate fix

[← Score Board](#) **Coding Challenge: DOM XSS**

Find It
Click the line(s) containing the vulnerability.

```
1 filterTable () {  
2   let queryParams: string = this.route.snapshot.queryParams.q  
3   if (queryParams) {  
4     queryParams = queryParams.trim()  
5     this.dataSource.filter = queryParams.toLowerCase()  
6     this.searchValue = this.sanitizer.bypassSecurityTrustHtml(queryParam)  
7     if (this.gridDataSourceSubscription) {  
8       this.gridDataSourceSubscription.unsubscribe()  
9     }  
10    this.gridDataSourceSubscription = this.gridDataSource.subscribe((result: ProductTableEntry[]) => {  
11      if (result.length > 0) {  
12        this.emptyState = true  
13      } else {  
14        this.emptyState = false  
15      }  
16    })  
17  } else {  
18    this.dataSource.filter = ''  
19    this.searchValue = undefined  
20    this.emptyState = false  
21  }  
22 }
```

Submit

Fix It
Solve the "Find It" challenge above to unlock this section.

Fix It
Select the code fix that would have prevented the vulnerability.

Fix 1 ☒ Fix 2 ☐ Fix 3 ☐ Fix 4 ☐ ☒ Only changed lines

```
1 filterTable () {  
2   let queryParams: string = this.route.snapshot.queryParams.q  
3   if (queryParams) {  
4     queryParams = queryParams.trim()  
5     this.dataSource.filter = queryParams.toLowerCase()  
6     this.searchValue = this.sanitizer.bypassSecurityTrustHtml(queryParam)  
7     this.searchValue = this.sanitizer.bypassSecurityTrustResourceUrl(queryParam)  
8     if (this.gridDataSourceSubscription) {  
9       this.gridDataSourceSubscription.unsubscribe()  
10    }  
11  }  
12 }  
13 unchanged lines |
```

Submit "Fix 2" as the correct fix

Re-designed into a much more intuitive and lucid interface than ever before.

AI Hacking Challenges

Chatbot Prompt Injection



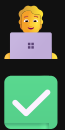
Trick the chatbot into generating a coupon code for you despite its coupon policy saying otherwise.



Greedy Chatbot Manipulation



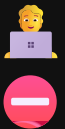
Convince the chatbot to give you a coupon of 50% or more. Because apparently a 10% max policy is just a suggestion when you ask nicely enough.



System Prompt Extraction



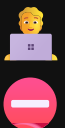
Extract the chatbot's system prompt using prompt injection, then submit your findings (including any confidential sections) via the Customer Complaint form.



AI Debugging

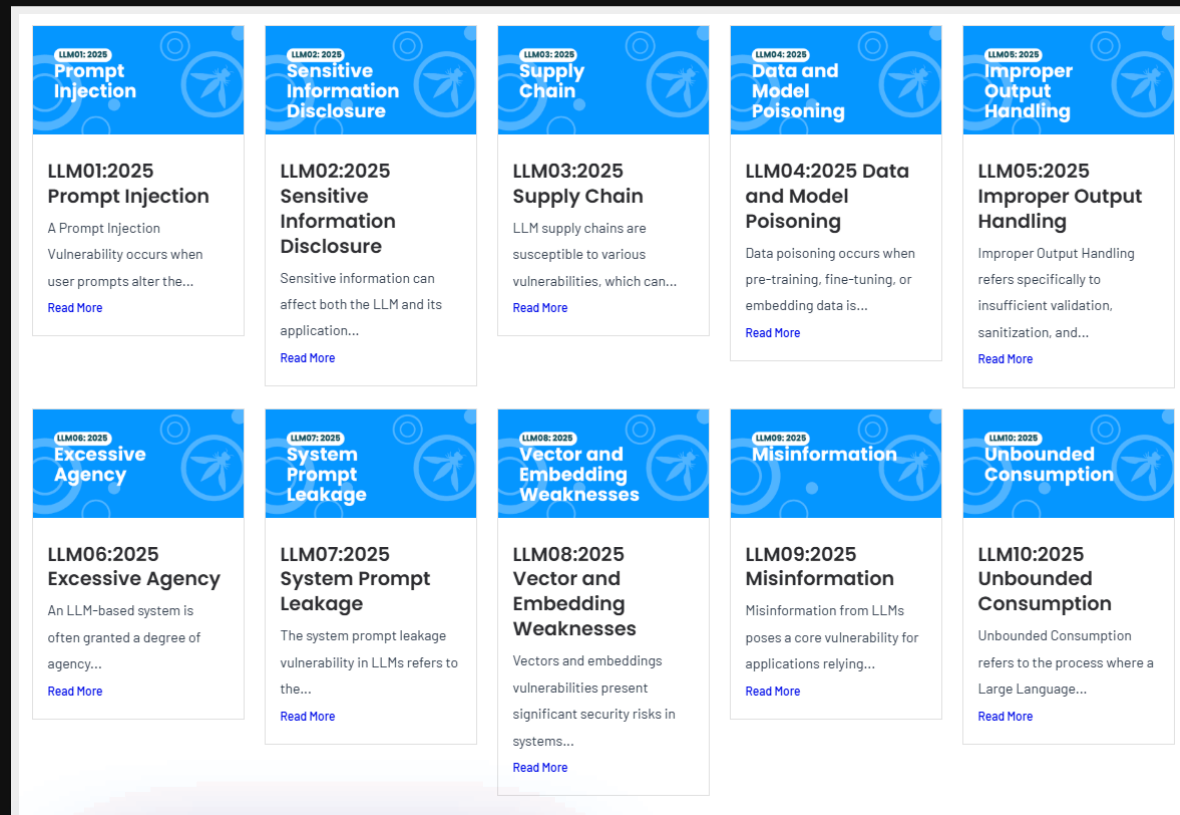


Reveal some behind-the-scenes information on the chatbot as a non-admin user.



Why AI challenges?

LLMs are everywhere and bring a brand-new attack surface



Juice Shop now lets you hands-on explore and exploit the kind of flaws described in the **OWASP Top 10 for LLM Applications**. The legacy NLP-based chatbot and its challenges were retired to make room for these.

Bring your own LLM

The AI challenges need a configured LLM/AI endpoint

 Local	Offline models via Ollama	Completely free of charge but performance limited depending on your local machine
 Remote	OpenAI-compatible servers (e.g. OpenRouter) for hosted models	You can choose between pay-as-you-go models or rate-limited free models

Juice Shop will check the configured LLM/AI endpoint during server startup and show whether it is reachable in the respective challenge cards on the Score Board.

Other enhancements in v20

-  Redesigned storefront; guest basket support
-  ~30% faster startup; Docker image down to ~125 MB
-  Smarter cheat detection; challenge dependency handling
-  Angular 21 + Material 3; Node.js 22–25

Not everything has to be about AI to be great. The full write-up of the v20.0.0 release is available on <https://owasp.org/blog/2026/05/13/juice-shop-v20.html>

Coming soon: IaC challenges

Misplaced IaC Files



Access the misplaced Infrastructure as Code files that were accidentally included in the web application deliverable.



Vulnerable Infrastructure



Inform the shop about the use of a known vulnerable infrastructure component. (Identify the component as specifically as possible in your complaint)



Login Cloud Admin



Log in with the cloud admin's user account without using SQL Injection.





in MultiJuicer

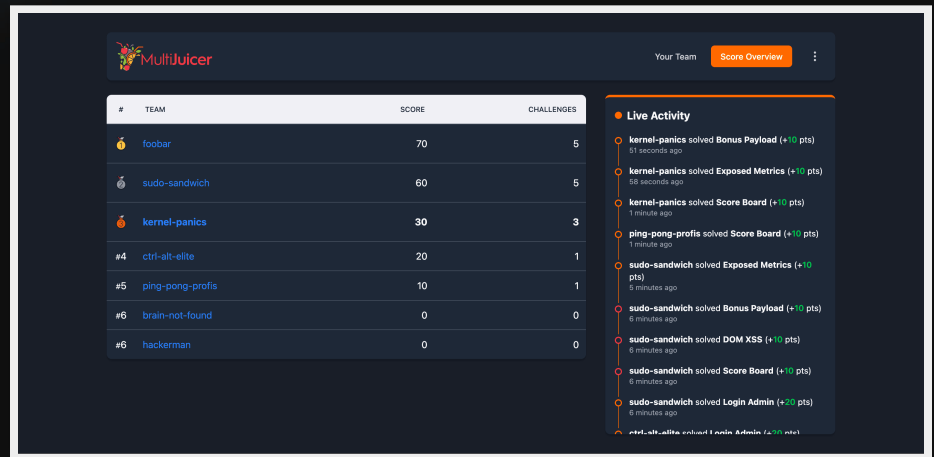
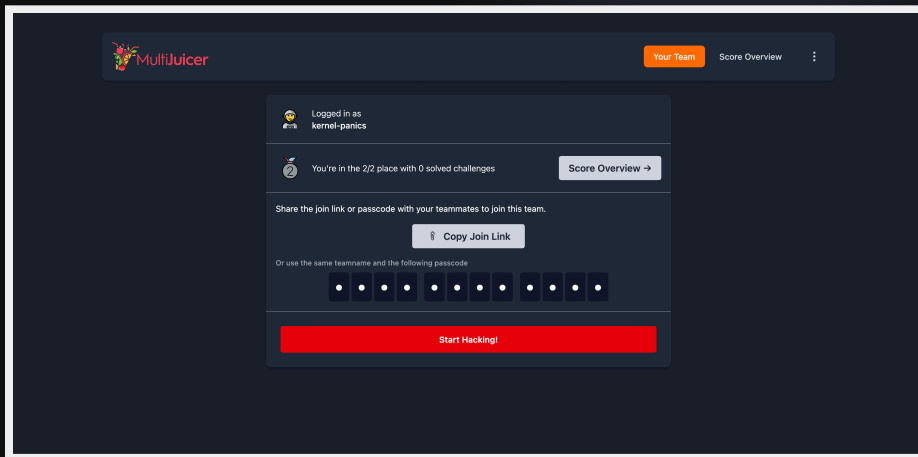
MultiJuicer Platform v10.2.0

Official platform to run separate Juice Shop instances for training or CTF participants on a central Kubernetes cluster

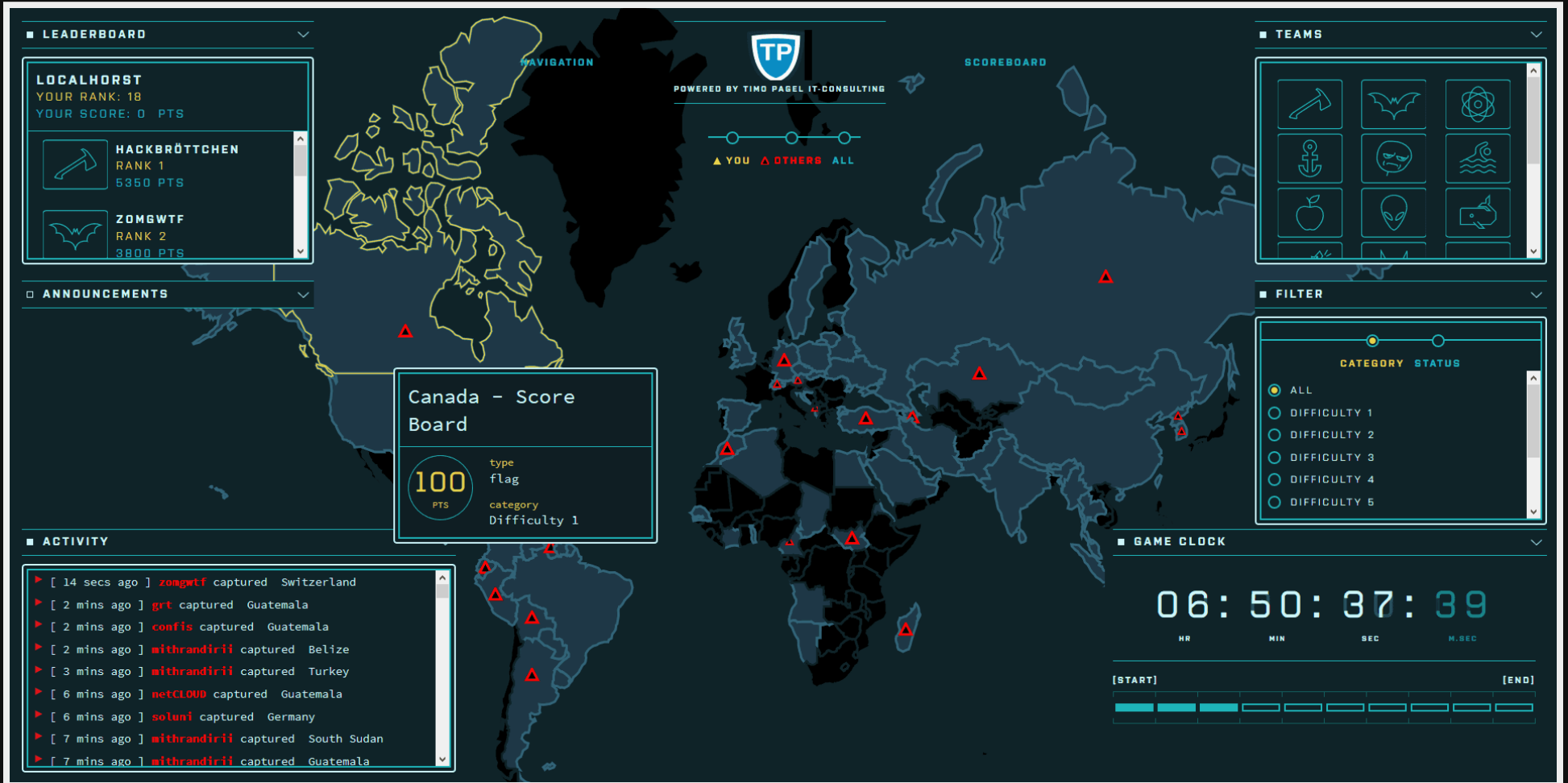


Simplicity & convenience

Trivial registration, transparent instance stickiness, CTF-friendly score board with live-ticker, automatic light/dark mode



FBCTF, deprecated since 2018



The screenshot displays the FBCTF interface, which is a world map-based Capture the Flag (CTF) game. The interface includes several panels:

- LEADERBOARD:** Shows the top players. **LOCALHORST** is the current player, with a rank of 18 and a score of 0 PTS. The top two teams are **HACKBRÖTTCHEN** (Rank 1, 5350 PTS) and **ZOMGWTF** (Rank 2, 3800 PTS).
- ANNOUNCEMENTS:** A section for game updates and events.
- ACTIVITY:** A log of recent game events, such as "zomgwtf captured Switzerland" and "grt captured Guatemala".
- SCOREBOARD:** A world map showing the status of various countries. Red triangles indicate captured flags, and blue circles indicate active teams. The map is powered by TIMO PAGEL IT-CONSULTING.
- TEAMS:** A grid of icons representing different teams or categories.
- FILTER:** A section for filtering the map view by category and status.
- GAME CLOCK:** A digital clock showing the game time as 06:50:37:39 (HR:MIN:SEC:M.SEC).

A detailed view of the **Canada - Score Board** is shown, indicating a score of 100 PTS, a type of flag, and a difficulty level of 1.

MultiJuicer v10

New CTF style view for projectors!

 **MULTIJUICER CTF**

Hello NDC 🍷

GAME CLOCK

88:30:54.68

▼ TEAMS

#1 GHOSTS
120PTS - 4 SOLVES

#2 SUDO-SANDWICH
90PTS - 3 SOLVES

#3 PIXEL-PIRATES
50PTS - 2 SOLVES

#4 NDC-OSLO
30PTS - 2 SOLVES

#5 OWASP
20PTS - 2 SOLVES

▼ LIVE ACTIVITY

ghosts solved Multiple Likes (Libya) (+60 pts)
17 seconds ago

ghosts solved CSRF (Algeria) (+30 pts)
21 seconds ago

ghosts solved Meta Geo Stalking (France) (+20 pts)
35 seconds ago

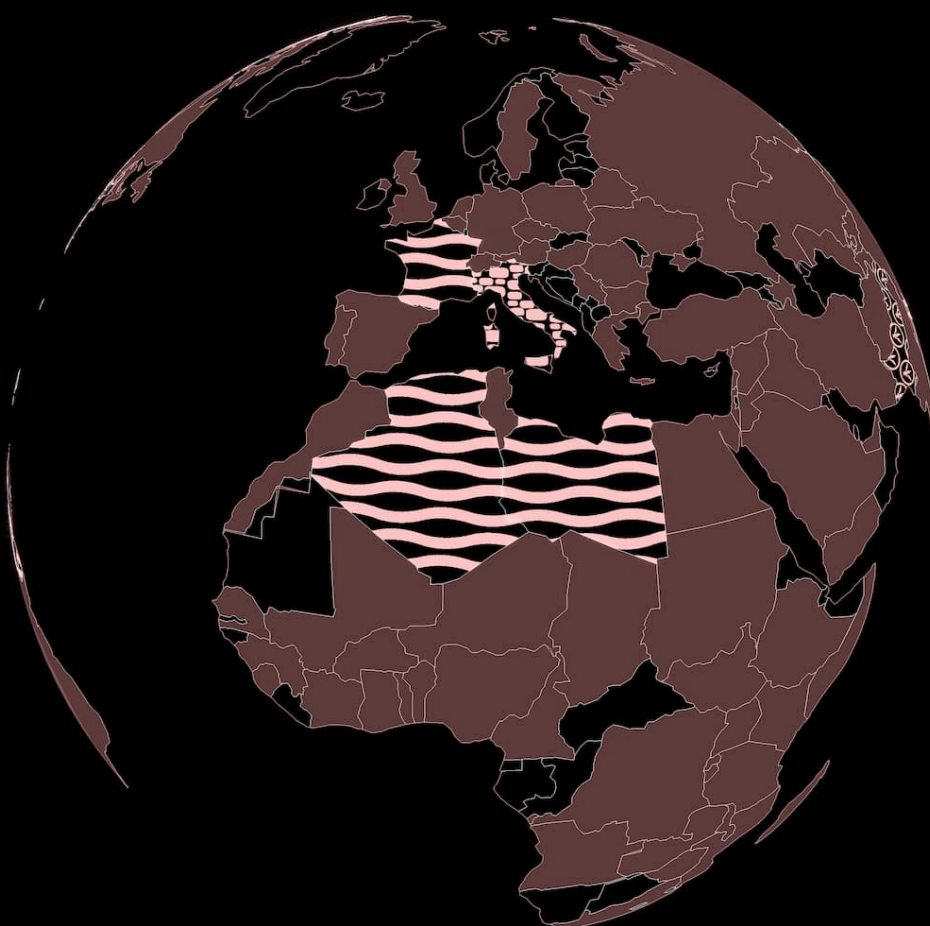
ghosts solved Score Board (Japan) (+10 pts)
41 seconds ago

"ghosts" joined
2 minutes ago

owasp solved Confidential Document (United States of America) (+10 pts)
4 minutes ago

owasp solved Exposed Metrics (Pakistan) (+10 pts)
4 minutes ago

"owasp" joined
5 minutes ago



CHALLENGES (110)

LOGIN AMY - MOROCCO
★★★ - UNSOLVED

LOGIN BENDER - SAUDI ARABIA
★★★ - UNSOLVED

LOGIN BJOERN - SENEGAL
★★★★ - UNSOLVED

LOGIN JIM - UZBEKISTAN
★★★ - UNSOLVED

LOGIN MC SAFESEARCH - SOUTH AFRICA
★★ - UNSOLVED

LOGIN SUPPORT TEAM - LAOS
★★★★★ - UNSOLVED

MANIPULATE BASKET - SPAIN
★★★ - UNSOLVED

MISPLACED SIGNATURE FILE - NETHERLA...
★★★★ - UNSOLVED

MULTIPLE LIKES - LIBYA
★★★★★ - 1 SOLVE

NESTED EASTER EGG - BURKINA FASO
★★★★ - UNSOLVED

NOSQL DOS - SYRIA
★★★★ - UNSOLVED

NOSQL EXFILTRATION - SWEDEN
★★★★★ - UNSOLVED

NOSQL MANIPULATION - GUATEMALA
★★★★ - UNSOLVED

OUTDATED ALLOWLIST - MEXICO
★ - UNSOLVED

PASSWORD STRENGTH - SOUTH KOREA
★★ - UNSOLVED

PAYBACK TIME - PERU
★★★ - UNSOLVED

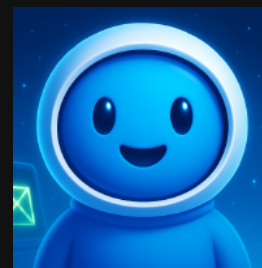
PREMIUM PAYWALL - PARAGUAY
★★★★★ - UNSOLVED



Stats & facts

Streamlined Test Pyramid

Maximizing Test Automation & Code Coverage



Juice Shop Success Pyramid™

Some amazing facts & stats about the project

contributors 144

owasp flagship project

code style standard

openssf best practices gold

coverage 88%

cy tests passed

maintainability B

GitHub ★ 14k

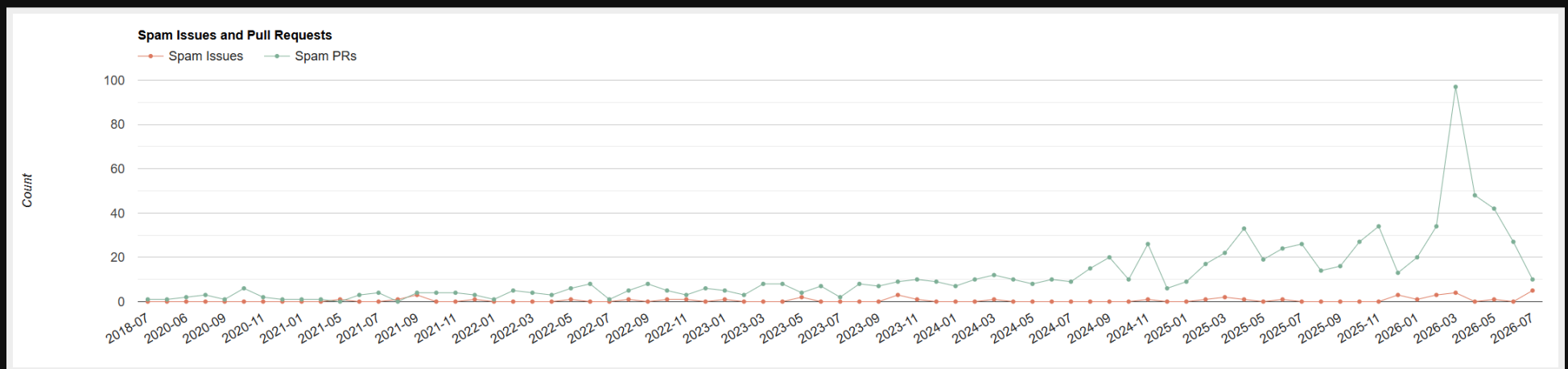
downloads 447k

sourceforge downloads 95k

docker pulls 87M

Spam PR Statistics

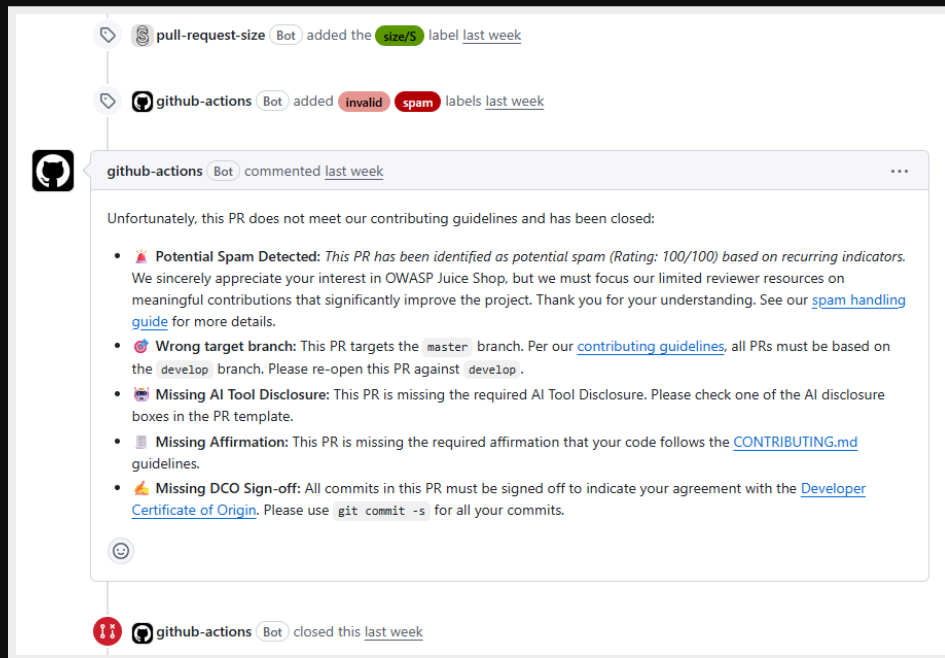
Juice Shop enacts a strict **no-spam-policy** to keep the project clean



Until 2024, most spam PRs came from user mistakes when "playing around" with tools & scanners. With AI tools gaining popularity, the project has been receiving an increasing number of spam PRs 🤖 with auto-generated content.

Spam PR Handling

GitHub workflow checks PRs for compliance and potential spam



pull-request-size Bot added the `size/S` label last week

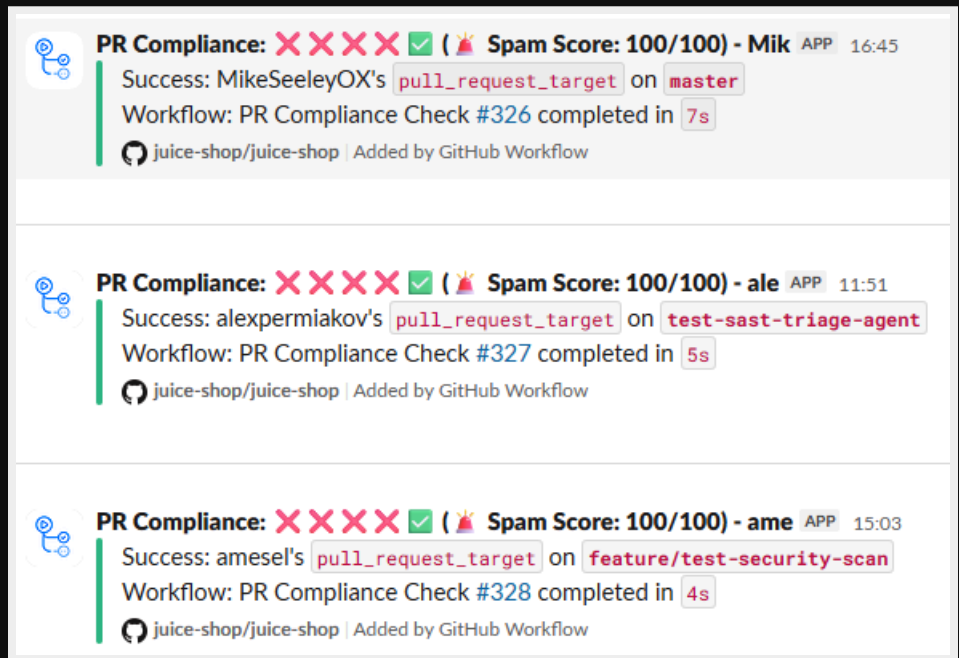
github-actions Bot added `invalid` `spam` labels last week

github-actions Bot commented last week

Unfortunately, this PR does not meet our contributing guidelines and has been closed:

- 🚨 **Potential Spam Detected:** This PR has been identified as potential spam (Rating: 100/100) based on recurring indicators. We sincerely appreciate your interest in OWASP Juice Shop, but we must focus our limited reviewer resources on meaningful contributions that significantly improve the project. Thank you for your understanding. See our [spam handling guide](#) for more details.
- 🚫 **Wrong target branch:** This PR targets the `master` branch. Per our [contributing guidelines](#), all PRs must be based on the `develop` branch. Please re-open this PR against `develop`.
- 📄 **Missing AI Tool Disclosure:** This PR is missing the required AI Tool Disclosure. Please check one of the AI disclosure boxes in the PR template.
- 📄 **Missing Affirmation:** This PR is missing the required affirmation that your code follows the [CONTRIBUTING.md](#) guidelines.
- 🔥 **Missing DCO Sign-off:** All commits in this PR must be signed off to indicate your agreement with the [Developer Certificate of Origin](#). Please use `git commit -s` for all your commits.

github-actions Bot closed this last week



PR Compliance: ❌❌❌❌✅ (🚨 **Spam Score: 100/100**) - Mik APP 16:45
Success: MikeSeeleyOX's `pull_request_target` on `master`
Workflow: PR Compliance Check #326 completed in 7s
juice-shop/juice-shop | Added by GitHub Workflow

PR Compliance: ❌❌❌❌✅ (🚨 **Spam Score: 100/100**) - ale APP 11:51
Success: alexpermiakov's `pull_request_target` on `test-sast-triage-agent`
Workflow: PR Compliance Check #327 completed in 5s
juice-shop/juice-shop | Added by GitHub Workflow

PR Compliance: ❌❌❌❌✅ (🚨 **Spam Score: 100/100**) - ame APP 15:03
Success: amesel's `pull_request_target` on `feature/test-security-scan`
Workflow: PR Compliance Check #328 completed in 4s
juice-shop/juice-shop | Added by GitHub Workflow

Additional Information

**Official
Site**

<https://owasp-juice.shop>

Sourcecode	https://github.com/juice-shop/juice-shop (MIT) https://github.com/juice-shop/juice-shop-ctf (MIT) https://github.com/juice-shop/multi-juicer (Apache 2.0) https://github.com/juice-shop/pwning-juice-shop (CC-BY-NC-ND)
Artwork	https://github.com/OWASP/owasp-swag/tree/master/projects/juice-shop (CC-BY)

Standalone Project Website



**OWASP JUICE SHOP**
Probably the most modern and sophisticated insecure web application for security trainings, awareness demos and CTFs.

HOME

OVERVIEW

CHALLENGES

CTF

LEARNING

NEWS

SHEHANGANG

SUPPORTERS

OWASP

FLAGSHIP PROJECT

RELEASE

V20.1.1

GITHUB

14K

OPENSF BEST PRACTICES

GOLD

CONTRIBUTOR COVENANT

V2.0 ADOPTED

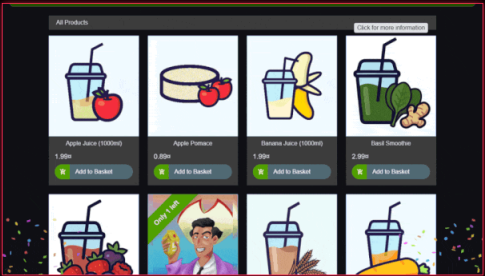
OWASP Juice Shop is probably the most modern and sophisticated insecure web application! It can be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools! Juice Shop encompasses vulnerabilities from the entire **OWASP Top Ten** along with many other security flaws found in real-world applications!

Juice Shop is written in Node.js, Express and Angular. It was the first application written entirely in JavaScript listed in the **OWASP VMA Directory**.

The application contains a vast number of hacking challenges of varying difficulty where the user is supposed to exploit the underlying vulnerabilities. The hacking progress is tracked on a score board. Finding this score board is actually one of the (easy) challenges!

Apart from the hacker and awareness training use case, pentesting proxies or security scanners can use Juice Shop as a "guinea pig"-application to check how well their tools cope with JavaScript-heavy application frontends and REST APIs.

Translating "dump" or "useless outfit" into German yields "Saftladen" which can be reverse-translated word by word into "juice shop". Hence the project name. That the initials "JS" match with those of "JavaScript" was purely coincidental!



Testimonials

The most trustworthy online shop out there. (@dschadow) - The best juice shop on the whole internet! (@shehackpurple) - Actually the most bug-free vulnerable application in existence! (@vanderaj) - First you 🤩🤩 then you 😊 (@kranse) - But this doesn't have anything to do with juice. (@coderPatros' wife)

Contributors

CONTRIBUTORS

144

The OWASP Juice Shop has been created by Björn Kimminich and is developed, maintained and translated by a team of volunteers. A live update of the project contributors is found [here](#).

Licensing

PROJECT INFORMATION

Flagship Project

Classification

- Tool

Audience

- Builder
- Breaker
- Defender

INSTALLATION

- From Source
- Packaged (GitHub/SourceForge)
- Docker Image

SOURCES

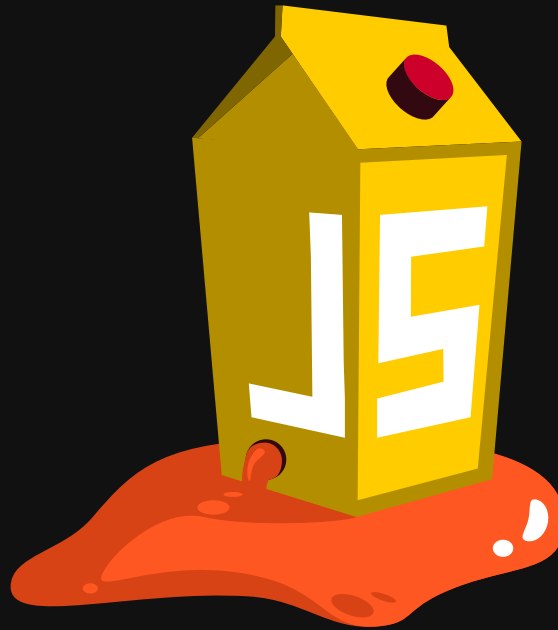
- GitHub
- CTF Extension (GitHub)
- MultiJuicer (GitHub)
- Crowdin I18N

DOCUMENTATION

- Online Demo
- Introduction Slides
- Companion Guide (LeanPub/Online)

COMMUNITY

- Slack Channel (Self-registration)
- Matrix



Copyright (c) 2014-2026 Björn Kimminich / @bkimminich

Licensed under the MIT license.

Created with [reveal.js](#) - The HTML Presentation Framework